

Знахідки

Summary

Вразлива версія:

```
=====
TOTAL SUMMARY
=====
Total checks: 26
Total found: 8
Total ok: 18
```

Не вразлива:

```
=====
TOTAL SUMMARY
=====
Total checks: 26
Total found: 5
Total ok: 21
```

1. Вразлива версія:

```
-----
Check: Retrieves book by title along with secret
Method: GET
Swagger path: /books/v1/{book_title}
Tested URL: http://127.0.0.1:5000/books/v1/victim\_secret\_book
Status: 200
Result: BOLA FOUND
Response: {'book_title': 'victim_secret_book', 'owner': 'victim_user', 'secret': 'secret_from_victim'}
```

Не вразлива:

```
-----
Check: Retrieves book by title along with secret
Method: GET
Swagger path: /books/v1/{book_title}
Tested URL: http://127.0.0.1:5000/books/v1/victim\_secret\_book
Status: 404
Result: OK: access denied
Response: {'status': 'fail', 'message': 'Book not found!'}
```

2. Вразлива версія:

```
-----  
Check: Retrieves user by username  
Method: GET  
Swagger path: /users/v1/{username}  
Tested URL: http://127.0.0.1:5000/users/v1/victim\_user  
Status: 200  
Result: BOLA FOUND  
Response: {'username': 'victim_user', 'email': 'victim@test.com'}
```

Не вразлива:

```
-----  
Check: Retrieves user by username  
Method: GET  
Swagger path: /users/v1/{username}  
Tested URL: http://127.0.0.1:5000/users/v1/victim\_user  
Status: 200  
Result: BOLA FOUND  
Response: {'username': 'victim_user', 'email': 'victim@test.com'}
```

3. Вразлива версія:

```
-----  
Check: Update users email  
Method: PUT  
Swagger path: /users/v1/{username}/email  
Tested URL: http://127.0.0.1:5000/users/v1/victim\_user/email  
Status: 204  
Result: BOLA FOUND  
Response:
```

Не вразлива:

```
-----  
Check: Update users email  
Method: PUT  
Swagger path: /users/v1/{username}/email  
Tested URL: http://127.0.0.1:5000/users/v1/victim\_user/email  
Status: 400  
Result: CHECK MANUALLY: unexpected status  
Response: {'status': 'fail', 'message': 'Please Provide a valid email address.'}
```

4. Вразлива версія:

```
-----  
Check: Update users password  
Method: PUT  
Swagger path: /users/v1/{username}/password  
Tested URL: http://127.0.0.1:5000/users/v1/victim\_user/password  
Status: 204  
Result: BOLA FOUND  
Response:
```

Не вразлива:

```
-----  
Check: Update users password  
Method: PUT  
Swagger path: /users/v1/{username}/password  
Tested URL: http://127.0.0.1:5000/users/v1/victim\_user/password  
Status: 204  
Result: BOLA FOUND  
Response:
```

5. Вразлива версія:

```
-----  
Check: User/password enumeration check  
Method: POST  
Swagger path: /users/v1/login  
Tested URL: http://127.0.0.1:5000/users/v1/login  
Status: None  
Result: POSSIBLE ENUMERATION: login responses are different (existing: 200, non-existing: 200)  
Response: {'existing_user_wrong_password': {'status': 'fail', 'message': 'Password is not correct for the given username.'}, 'non_existing_user': {'status': 'fail', 'message': 'Username does not exist'}}
```

Не вразлива:

```
-----  
Check: User/password enumeration check  
Method: POST  
Swagger path: /users/v1/login  
Tested URL: http://127.0.0.1:5000/users/v1/login  
Status: None  
Result: OK: login responses look similar  
Response: {'existing_user_wrong_password': {'status': 'fail', 'message': 'Username or Password Incorrect!'}, 'non_existing_user': {'status': 'fail', 'message': 'Username or Password Incorrect!'}}
```

6. Вразлива версія:

```
-----  
Check: Retrieves book by title along with secret  
Method: GET  
Swagger path: /books/v1/{book_title}  
Tested URL: http://127.0.0.1:5000/books/v1/victim\_secret\_book  
Status: 200  
Result: EXCESSIVE DATA EXPOSURE FOUND: ['secret']  
Response: {'book_title': 'victim_secret_book', 'owner': 'victim_user', 'secret': 'secret_from_victim'}
```

Не вразлива:

```
-----  
Check: Retrieves book by title along with secret  
Method: GET  
Swagger path: /books/v1/{book_title}  
Tested URL: http://127.0.0.1:5000/books/v1/victim\_secret\_book  
Status: 404  
Result: OK: endpoint did not return 200  
Response: {'status': 'fail', 'message': 'Book not found!'}
```

7. Вразлива версія:

```
-----  
Check: Retrieves currently logged in user  
Method: GET  
Swagger path: /me  
Tested URL: http://127.0.0.1:5000/me  
Status: 500  
Result: CHECK MANUALLY: server error – possible information disclosure  
Response: <!doctype html>  
<html lang=en>  
  <head>  
    <title>AttributeError: 'NoneType' object has no attribute 'username'  
// Werkzeug Debugger</title>  
    <link rel="stylesheet" href="?__debugger__=yes&cmd=resource&f=style.css">  
    <link rel="shortcut icon"  
      href="?__debugger__=yes&cmd=resource&f=console.png">  
    <script src="?__debugger__=yes&cmd=resource&f=debugger.js"></script>  
    <script>  
      var CONSOLE_MODE = false,  
          EVALEX = true,  
          EVALEX_TRUSTED = false,  
          SECRET = "odx0IAyuERiWJZo652ym";  
    </script>  
  </head>  
  <body style="background-color: #fff">  
    <div class="debugger">  
<h1>AttributeError</h1>
```

Не вразлива:

```

-----
Check: Retrieves currently logged in user
Method: GET
Swagger path: /me
Tested URL: http://127.0.0.1:5000/me
Status: 500
Result: CHECK MANUALLY: server error – possible information disclosure
Response: <!doctype html>
<html lang=en>
  <head>
    <title>AttributeError: 'NoneType' object has no attribute 'username'
// Werkzeug Debugger</title>
    <link rel="stylesheet" href="?"__debugger__=yes&cmd=resource&f=style.css">
    <link rel="shortcut icon"
      href="?"__debugger__=yes&cmd=resource&f=console.png">
    <script src="?"__debugger__=yes&cmd=resource&f=debugger.js"></script>
    <script>
      var CONSOLE_MODE = false,
          EVALEX = true,
          EVALEX_TRUSTED = false,
          SECRET = "odx0IAyuERiWJZo652ym";
    </script>
  </head>
  <body style="background-color: #fff">
    <div class="debugger">
<h1>AttributeError</h1>

```

8. Вразлива версія:

```

-----
Check: Retrieves all details for all users
Method: GET
Swagger path: /users/v1/_debug
Tested URL: http://127.0.0.1:5000/users/v1/\_debug
Status: 200
Result: EXCESSIVE DATA EXPOSURE FOUND: ['users[0].admin', 'users[0].password', 'users[1]
Response: {'users': [{'admin': False, 'email': 'mail1@mail.com', 'password': 'pass1', 'u

```

Не вразлива:

```
-----  
Check: Retrieves all details for all users  
Method: GET  
Swagger path: /users/v1/_debug  
Tested URL: http://127.0.0.1:5000/users/v1/\_debug  
Status: 200  
Result: EXCESSIVE DATA EXPOSURE FOUND: ['users[0].admin', 'users[0].password', 'users[  
Response: {'users': [{'admin': False, 'email': 'mail1@mail.com', 'password': 'pass1',
```